

Remote Working, Data Protection & Endpoint Security Policy

(ISO/IEC 27001:2022 – Annex A 6.7, 8.7, 8.10)

Purpose

This policy defines security requirements for remote working to prevent data leakage, malware infections, and unauthorized access to Clinic information assets.

Scope

This policy applies to all Clinic participants, employees, and contractors accessing Clinic systems remotely, including AWS environments, documentation repositories, and communication platforms.

Remote Working Controls

1. Data Protection & Leakage Prevention

- Clinic data must only be accessed through authorized accounts.
- Storage of Clinic data on personal devices is prohibited unless encrypted.
- Screenshots, logs, or reports containing sensitive information must not be shared externally.
- Confidential data must not be uploaded to unauthorized third-party services.

2. Endpoint Security Requirements

All remote endpoints must:

- Have OS-level security updates enabled
- Use antivirus or built-in endpoint protection (Windows Defender, macOS XProtect)
- Lock the screen after inactivity
- Be protected with strong authentication (password + biometric where available)

3. Malware Detection and Monitoring

- AWS GuardDuty is used to detect:
 - Suspicious IAM activity

- Unauthorized API calls
 - Potential credential compromise
- AWS CloudTrail logs are enabled and protected to support investigation and incident response.
- Malware-related alerts must be reported immediately to the Security Manager.

4. Secure Network Access (VPN Requirement)

- VPN is required when accessing Clinic systems from:
 - Public Wi-Fi
 - Untrusted networks
- VPN traffic must use encrypted tunnels.
- Direct administrative access to AWS must not be performed from unsecured networks.

5. Incident Reporting

- Suspected malware infection, data leakage, or unauthorized access must be reported immediately.
- Incidents are handled in accordance with the Clinic's Incident Management procedures.

Enforcement

Failure to comply with this policy may result in access revocation, disciplinary action, or removal from Clinic activities.